

Replace and modernize legacy VPN  
architectures with a cloud-native Zscaler  
Zero Trust solution to reduce attack

## Group details:-

| s.no | Name          | College name                                 | Email                                                                      |
|------|---------------|----------------------------------------------|----------------------------------------------------------------------------|
| 1    | KEERTHANA.M   | Shree Venkateshwara Arts and Science College | <a href="mailto:keerthanam2023cs@gmail.com">keerthanam2023cs@gmail.com</a> |
| 2    | GOKULAPRIYA.M | Shree Venkateshwara Arts and Science College | gokulapriya334@gmail.com                                                   |
| 3    | GIRIJA.R      | Shree Venkateshwara Arts and Science College | girijar2023cs@gmail.com                                                    |
| 4    | NANDHINI.S    | Shree Venkateshwara Arts and Science College | nandhinis2023cs@gmail.com                                                  |

## PROJECT DETAILS :-

**TITLE:-** Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement

### **Overview:-**

In response to the evolving threat landscape and the dissolution of the traditional network perimeter, this project initiates a fundamental shift in our security architecture. We will be decommissioning our legacy VPN infrastructure, which relies on an outdated castle-and-moat model that grants excessive network access and is vulnerable to lateral threat movement. To replace it, we are adopting a cloud-native, Zero Trust approach powered by Zscaler. This new architecture is built on the principle of "never trust, always verify," ensuring that users are connected to applications, not to the network. By making applications invisible to the internet and establishing direct, secure user-to-app connections, we will drastically reduce our attack surface. This modern solution eliminates the risk of lateral movement, as threats can no longer traverse a flat network. Furthermore, it provides a superior, high-performance experience for our hybrid workforce, decoupling security from data center backhauling. The transition to Zscaler will not only bolster our security posture but also enhance agility and reduce the operational overhead associated with managing legacy hardware. This initiative is a critical step in future-proofing our organization against sophisticated cyber threats

## ABSTRACT:-

This project details the strategic migration from a legacy Virtual Private Network (VPN) infrastructure to a cloud-native Zero Trust Network Access (ZTNA) solution provided by Zscaler. The primary driver for this initiative is the fundamental inadequacy of traditional VPNs in the modern threat landscape.

Legacy architectures operate on a "connect first, verify later" model, granting users broad access to the corporate network and, consequently, creating a significant risk of lateral movement by malicious actors. This expansive attack surface, combined with the operational overhead of managing physical appliances and the poor user experience associated with hair-pinned traffic, renders the existing model both insecure and inefficient for today's hybrid workforce.

The proposed solution leverages the Zscaler Zero Trust Exchange, a global, cloudnative platform that shifts connectivity from a network-centric to an identity and application-centric model. By making corporate applications invisible to the internet and establishing direct, secure connections between verified users and specific applications, the new architecture eliminates the concept of network-based privileges. This approach ensures that users connect to the applications they need, not the underlying network, thereby completely neutralizing the threat of lateral movement. Furthermore, it improves performance by steering traffic directly to Zscaler's edge nodes, optimizing the user experience regardless of their location.

The expected outcomes of this modernization project are multifaceted. We anticipate a drastic reduction in the organization's attack surface and the complete elimination of lateral movement risks. This will be coupled with a simplified, scalable security posture managed from a unified cloud console, reducing operational costs and complexity. Ultimately, this transition will not only fortify our cyber defenses against sophisticated threats but also enable a secure, highperformance, and agile work environment, future-proofing the organization's security architecture.

use case scenario:-

stage 1:

Third-Party Vendor Access to Finance Application

stage 2:

Research Assistant Access to High-Performance  
Computing Cluster

stage 3:

Administrative Staff Access to Internal File Server

Stage 4:

IT Administrator Secure Access to Server Management  
Interfaces

Stage 5:

Visiting Professor Access to Library Resources

## STAGE 1 :-

**Title:-** Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement

### Overview:

This project aims to modernize the organization's remote access and network security by replacing the legacy Virtual Private Network (VPN) infrastructure with a cloud-native Zero Trust solution using Zscaler Private Access (ZPA). The current VPN model follows a traditional "castle-and-moat" security approach, where users are trusted once they successfully connect to the network. This approach grants broad network access, which increases the attack surface and exposes the organization to potential security risks.

One of the main challenges with the existing VPN system is the risk of lateral movement. If a cyber attacker gains access to a single compromised credential, they may be able to move across the internal network, discover other systems, and access sensitive resources. This type of attack can lead to widespread security breaches and significant data loss. In addition to security risks, traditional VPN infrastructure requires continuous maintenance, including patching, monitoring, and scaling hardware appliances to support increasing numbers of remote users.

Another issue is the poor user experience caused by traffic backhauling. In many VPN environments, user traffic is routed through centralized gateways before reaching applications, which increases latency and slows down performance for remote employees.

To address these issues, the organization plans to implement Zscaler Private Access (ZPA), which follows the Zero Trust principle of "never trust, always verify." Instead of granting users access to the entire network, ZPA connects users only to the specific applications they are authorized to access. Internal applications remain hidden from the public internet, eliminating exposed ports and reducing the attack surface.

When a user requests access, ZPA verifies their identity through integrations with identity providers such as Azure Active Directory and checks device security posture. Once verified, a secure encrypted micro-tunnel is established between the user and the application.

This approach prevents lateral movement, enhances security, improves performance for remote users, and simplifies IT operations through a scalable cloud-based platform.

## **List of Vulnerability Table**

| <b>S.no</b> | <b>Category Name</b>                   | <b>Vulnerability Name</b>                         | <b>CWE/CWC no</b> |
|-------------|----------------------------------------|---------------------------------------------------|-------------------|
| 1           | Broken Access Control                  | <b>Absolute Path Traversal</b>                    | CWE-36            |
| 2           | Security Misconfiguration              | <b>Configuration</b>                              | CWE-16            |
| 3           | Software Supply Chain Failures         | <b>Unimplemented or Unsupported Feature in UI</b> | CWE-447           |
| 4           | Cryptographic Failures                 | <b>Weak Encoding for Password</b>                 | CWE-261           |
| 5           | Injection                              | <b>Improper Input Validation</b>                  | CWE-20            |
| 6           | Insecure Design                        | <b>Incorrect User Management</b>                  | CWE-286           |
| 7           | Authentication Failures                | <b>Improper Authentication</b>                    | CWE-287           |
| 8           | Software or Data Integrity Failures    | <b>Untrusted Search Path</b>                      | CWE-426           |
| 9           | Security Logging and Alerting Failures | <b>Insufficient Logging</b>                       | CWE-778           |
| 10          | Mishandling of Exceptional Conditions  | <b>Uncaught Exception</b>                         | CWE-248           |

# REPORT

## 1. Vulnerability name : Absolute Path Traversal

**CWE/CVE number :** 36

**OWASP category:** A01:2025 Broken Access Control

**Description:** Absolute Path Traversal is a vulnerability where an attacker can access sensitive files on a server by specifying a full system file path (e.g., /etc/passwd or C:\Windows\system.ini). This occurs when an application does not properly validate user-supplied file paths. As a result, attackers may read restricted system or application files.

**Business impact :** This vulnerability can expose sensitive data such as configuration files, credentials, or source code. It may lead to data breaches, system compromise, and unauthorized access to internal resources. Organizations may face financial loss, reputational damage, and compliance issues.

The screenshot shows the MITRE CWE website page for CWE-36: Absolute Path Traversal. The page includes the MITRE logo, navigation links (Home, About, Learn, Access Content, Community, Search), and a search bar. The main content area displays the vulnerability details for CWE-36, including its ID, mapping to the NIST vulnerability taxonomy (ALLOWED), and a description of the vulnerability. The page also features a 'View customized information' section with tabs for Conceptual, Operational, Mapping Friendly, Complete, and Custom. The 'Description' tab is selected, showing the vulnerability's impact and details.

**CWE-36: Absolute Path Traversal**

Weakness ID: 36  
Vulnerability Mapping: **ALLOWED**  
Abstraction: Base

View customized information:

**Description**

The product uses external input to construct a pathname that should be within a restricted directory, but it does not properly neutralize absolute path sequences such as "/abs/path" that can resolve to a location that is outside of that directory.

**Extended Description**

This allows attackers to traverse the file system to access files or directories that are outside of the restricted directory.

**Common Consequences**

| Impact                                | Details                                                                                                                                                                                |
|---------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Execute Unauthorized Code or Commands | <b>Scope: Integrity, Confidentiality, Availability</b><br>The attacker may be able to create or overwrite critical files that are used to execute code, such as programs or libraries. |



## 2. Vulnerability name : Configuration

**CWE/CVE number : 16**

### **OWASP category: A02:2025 Security Misconfiguration**

**Description:** Configuration vulnerability occurs when systems, applications, or devices are not configured according to security best practices or organizational standards.

This may include default settings, unnecessary services enabled, improper access controls, weak security parameters, or missing hardening configurations. Such misconfigurations can expose the system to unauthorized access, data leakage, or exploitation by attackers.

### **Business impact :**

Improper or insecure configuration of systems and applications can expose the organization to significant security risks. Attackers may exploit misconfigurations to gain unauthorized access, compromise sensitive data, or disrupt critical services. This can lead to operational downtime, data breaches, financial losses, regulatory compliance violations, and damage to the organization's reputation and customer trust. Ensuring proper configuration management is essential to maintain system security, availability, and business continuity.

This website utilizes technologies such as cookies to enable essential site functionality, as well as for analytics, personalization, and targeted advertising. To learn more, view the following link: [Privacy Policy](#)

[Manage Preferences](#)

Home > CWE List > CWE - Individual Dictionary Definition (4.19.1)

ID Lookup:  Go

[Home](#) | [About](#) | [Learn](#) | [Access Content](#) | [Community](#) | [Search](#)

### CWE CATEGORY: Configuration

Category ID: 16

**Vulnerability Mapping: PROHIBITED**

**Summary**

Weaknesses in this category are typically introduced during the configuration of the software.

**Membership**

| Nature   | Type | ID   | Name                                                                             |
|----------|------|------|----------------------------------------------------------------------------------|
| MemberOf |      | 635  | <a href="#">Weaknesses Originally Used by NVD from 2008 to 2016</a>              |
| MemberOf |      | 933  | <a href="#">OWASP Top Ten 2013 Category A5 - Security Misconfiguration</a>       |
| MemberOf |      | 1032 | <a href="#">OWASP Top Ten 2017 Category A6 - Security Misconfiguration</a>       |
| MemberOf |      | 1349 | <a href="#">OWASP Top Ten 2021 Category A05:2021 - Security Misconfiguration</a> |
| MemberOf |      | 1437 | <a href="#">OWASP Top Ten 2025 Category A02:2025 - Security Misconfiguration</a> |

**Vulnerability Mapping Notes**

**Usage: PROHIBITED** (this CWE ID must not be used to map to real-world vulnerabilities)

**Reason:** Category

**Rationale:**

This entry is a Category. Using categories for mapping has been discouraged since 2019. Categories are informal organizational groupings of weaknesses that can help CWE users with data aggregation, navigation, and browsing. However, they are not weaknesses in themselves [REF-1287]. This CWE entry may have become widely-used because of NIST's usage in NVD from 2008 to 2016 (see [CWE-635](#) view, updated to the [CWE-1003](#) view in 2016). Mapping is also Prohibited because this entry's status is Obsolete.

**Comments:**

### 3. Vulnerability name : Unimplemented or Unsupported Feature in UI

**CWE/CVE number : 447**

**OWASP category:** A03:2025 Software Supply Chain Failures

**Description:** This vulnerability occurs when the user interface (UI) displays features, buttons, links, or options that are not fully implemented, functional, or supported by the backend system. When users interact with these elements, they may lead to errors, unexpected behavior, or no response. Such features can confuse users and may sometimes expose system information through error messages or incomplete functionality.

**Business impact :** The presence of unimplemented or unsupported features in the UI can negatively impact user experience and system reliability. Users may become confused or lose trust in the application when certain features do not function as expected. Additionally, these issues may expose internal system details through error messages, which could potentially be leveraged by attackers to gather information about the system. Over time, this can lead to reduced productivity, reputational damage, and increased support or maintenance costs for the organization.

The screenshot shows the NVD entry for CWE-447: Unimplemented or Unsupported Feature in UI (4.19.1). The page includes a navigation bar with links like Home, About, Learn, Access Content, Community, and Search. The main content area is titled 'CWE-447: Unimplemented or Unsupported Feature in UI' and provides details about the weakness, including its ID, vulnerability mapping (ALLOWED), and abstraction (Base). It also features tabs for viewing customized information (Conceptual, Operational, Mapping Friendly, Complete, Custom) and sections for Description, Common Consequences, Potential Mitigations, and Relationships.

Home > CWE List > CWE-447: Unimplemented or Unsupported Feature in UI (4.19.1) ID Lookup: Go

Home About Learn Access Content Community Search

### CWE-447: Unimplemented or Unsupported Feature in UI

Weakness ID: 447  
Vulnerability Mapping: ALLOWED  
Abstraction: Base

View customized information: Conceptual Operational Mapping Friendly Complete Custom

**Description**  
A UI function for a security feature appears to be supported and gives feedback to the user that suggests that it is supported, but the underlying functionality is not implemented.

**Common Consequences**

| Impact                                 | Details      |
|----------------------------------------|--------------|
| Varies by Context;<br>Unexpected State | Scope: Other |

**Potential Mitigations**

| Phase(s) | Mitigation                                                      |
|----------|-----------------------------------------------------------------|
| Testing  | Perform functionality testing before deploying the application. |

**Relationships**

**Relevant to the view "Research Concepts" (View-1000)**

| Nature  | Type | ID  | Name                                        |
|---------|------|-----|---------------------------------------------|
| ChildOf | ✓    | 446 | UI Discrepancy for Security Feature         |
| ChildOf | ✓    | 671 | Lack of Administrator Control over Security |

**Relevant to the view "Software Development" (View-699)**

| Nature | Type | ID | Name |
|--------|------|----|------|
|--------|------|----|------|

## 4. Vulnerability name : Weak Encoding for Password

**CWE/CVE number :** 261

**OWASP category:** A04:2025 Cryptographic Failures

**Description:** This vulnerability occurs when passwords are stored or transmitted using weak encoding or reversible methods such as Base64, plain text, or weak hashing algorithms instead of strong cryptographic hashing techniques. Weak encoding does not adequately protect password data, making it easier for attackers to decode or recover the original passwords if they gain access to the stored data or intercepted traffic..

**Business impact:** Weak encoding for passwords can significantly compromise the security of user accounts and sensitive systems. If attackers obtain access to encoded or poorly protected passwords, they can easily decode them and gain unauthorized access to user accounts, administrative systems, or confidential information. This may lead to data breaches, unauthorized transactions, service disruptions, and loss of customer trust. Additionally, such security weaknesses may result in regulatory compliance issues and financial or reputational damage to the organization

 **Common Weakness Enumeration**  
A community-developed list of SW & HW weaknesses that can become vulnerabilities

 **New to CWE?**  
[Start here!](#)

Home > CWE List > CWE-261: Weak Encoding for Password (4.19.1)

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

**CWE-261: Weak Encoding for Password**

Weakness ID: 261  
Vulnerability Mapping: **ALLOWED**  
Abstraction: Base

View customized information: Conceptual Operational Mapping Friendly Complete Custom

**Description**  
Obscuring a password with a trivial encoding does not protect the password.

**Extended Description**  
Password management issues occur when a password is stored in plaintext in an application's properties or configuration file. A programmer can attempt to remedy the password management problem by obscuring the password with an encoding function, such as base 64 encoding, but this effort does not adequately protect the password.

**Common Consequences**

| Impact                             | Details               |
|------------------------------------|-----------------------|
| Gain Privileges or Assume Identity | Scope: Access Control |

**Potential Mitigations**

| Phase(s) | Mitigation                                                                                          |
|----------|-----------------------------------------------------------------------------------------------------|
|          | Passwords should be encrypted with keys that are at least 128 bits in length for adequate security. |

**Relationships**

## 5. Vulnerability name : Improper Input Validation

CWE/CVE number :20

OWASP category: A05:2025 Injection

**Description:** Improper Input Validation occurs when an application does not properly validate or sanitize user-supplied input before processing it. This may allow attackers to submit unexpected, malformed, or malicious data that the system is not designed to handle. Without proper validation, the application may process harmful input that can manipulate system behavior, access unauthorized data, or trigger security vulnerabilities.

**Business impact:** Improper input validation can expose the application to multiple security risks such as unauthorized access, data manipulation, injection attacks, and system compromise. Attackers may exploit this weakness to bypass security controls, access sensitive information, or disrupt normal system operations. This can lead to data breaches, service downtime, financial losses, regulatory compliance issues, and damage to the organization's reputation and customer trust

### CWE-20: Improper Input Validation

Weakness ID: 20  
Vulnerability Mapping: **DISCOURAGED**  
Abstraction: Class

View customized information: Conceptual Operational Mapping Friendly Complete Custom

▼ Description

The product receives input or data, but it does not validate or incorrectly validates that the input has the properties that are required to process the data safely and correctly.

```
graph LR; User((User)) -- "Bad Data" --> Product[Product]; User -- "No Validation" --> Product; User -- "Input Validated" --> Product;
```

▼ Extended Description

Input validation is a frequently-used technique for checking potentially dangerous inputs in order to ensure that the inputs are safe for processing within the code, or when communicating with other components.

Input can consist of:

- raw data - strings, numbers, parameters, file contents, etc.
- metadata - information about the raw data, such as headers or size

Data can be simple or structured. Structured data can be composed of many nested layers, composed of combinations of metadata and raw data, with other simple or structured data.

Many properties of raw data or metadata may need to be validated upon entry into the code, such as:

- specified quantities such as size, length, frequency, price, rate, number of operations, time, etc.

## 6. Vulnerability name : Incorrect User Management

CWE/CVE number : 286

OWASP category: A06:2025 Insecure Design

**Description:** Incorrect User Management occurs when **user accounts, roles, or permissions are not properly created, maintained, or removed within an application or system**. This may include issues such as improper role assignments, inactive accounts remaining active, lack of proper access control, or failure to enforce strong authentication and authorization policies. Such weaknesses can allow users to have more privileges than necessary or retain access even after it is no longer required.

**Business impact:** Incorrect user management can lead to unauthorized access to sensitive systems and data. Users with excessive or outdated privileges may unintentionally or intentionally misuse access, which could result in data leakage, modification of critical information, or disruption of services. Additionally, failure to properly manage user accounts can create security risks, compliance violations, and operational issues, potentially leading to financial loss and reputational damage for the organization.

The screenshot displays the CWE-286: Incorrect User Management page. At the top, the CWE logo and navigation links are visible. The page title is "CWE-286: Incorrect User Management". Below the title, the "Weakness ID: 286" is shown, followed by "Vulnerability Mapping: ALLOWED (with careful review of mapping notes)" and "Abstraction: Class". A section for "View customized information" includes buttons for "Conceptual", "Operational", "Mapping Friendly", "Complete", and "Custom". The "Description" section states: "The product does not properly manage a user within its environment." The "Extended Description" section states: "Users can be assigned to the wrong group (class) of permissions resulting in unintended access rights to sensitive objects." The "Common Consequences" section includes a table for "Impact" and "Details". The "Relationships" section includes a table for "Relevant to the view 'Research Concepts' (View-1000)".

**CWE-286: Incorrect User Management**

Weakness ID: 286  
Vulnerability Mapping: ALLOWED (with careful review of mapping notes)  
Abstraction: Class

View customized information:

**Description**  
The product does not properly manage a user within its environment.

**Extended Description**  
Users can be assigned to the wrong group (class) of permissions resulting in unintended access rights to sensitive objects.

**Common Consequences**

| Impact            | Details      |
|-------------------|--------------|
| Varies by Context | Scope: Other |

**Relationships**

**Relevant to the view "Research Concepts" (View-1000)**

| Nature   | Type | ID  | Name                                   |
|----------|------|-----|----------------------------------------|
| ChildOf  | P    | 284 | Improper Access Control                |
| ParentOf | U    | 842 | Placement of User into Incorrect Group |

**Relevant to the view "Architectural Concepts" (View-1008)**

| Nature | Type | ID | Name |
|--------|------|----|------|
|--------|------|----|------|

## 7. Vulnerability name : Improper Authentication

CWE/CVE number : 287

OWASP category: A07:2025 Authentication Failures

**Description:** Improper Authentication occurs when an application **fails to correctly verify the identity of a user before granting access to the system or its resources**. This can happen due to weak authentication mechanisms, improper session handling, missing authentication checks, or flaws in the login process. As a result, attackers may bypass authentication controls and gain unauthorized access to the application..

**Business impact:** Improper authentication can allow unauthorized users to access sensitive systems, accounts, or confidential data. Attackers may exploit this weakness to impersonate legitimate users, perform unauthorized actions, or compromise critical business information. This can result in data breaches, financial losses, operational disruption, regulatory compliance issues, and significant damage to the organization's reputation and customer trust.

 **Common Weakness Enumeration**  
A community-developed list of SW & HW weaknesses that can become vulnerabilities

Top 25

Top HW CWE

New to CWE?  
[Start here!](#)

Home > CWE List > CWE-287: Improper Authentication (4.19.1)

Home | About | Learn | Access Content | Community | Search

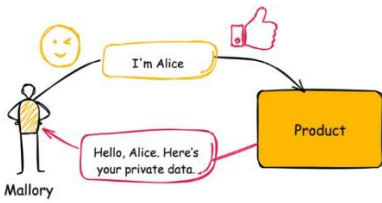
**CWE-287: Improper Authentication**

Weakness ID: 287  
Vulnerability Mapping: **DISCOURAGED**  
Abstraction: Class

View customized information: Conceptual Operational Mapping Friendly Complete Custom

**Description**

When an actor claims to have a given identity, the product does not prove or insufficiently proves that the claim is correct.



```
graph LR; Mallory((Mallory)) -- "I'm Alice" --> Product[Product]; Product -- "Hello, Alice. Here's your private data." --> Mallory;
```

**Alternate Terms**

|                  |                                                                                                                                |
|------------------|--------------------------------------------------------------------------------------------------------------------------------|
| authentification | An alternate term is "authentification", which appears to be most commonly used by people from non-English-speaking countries. |
| AuthN            | "AuthN" is typically used as an abbreviation of "authentication" within the web application security community. It is also     |



## 8. Vulnerability name : Untrusted Search Path

CWE/CVE number : 426

OWASP category: A08:2025 Software or Data Integrity Failures

**Description:** Untrusted Search Path vulnerability occurs when an application **searches for executable files, libraries, or resources in directories that are not trusted or properly controlled**. If the system loads files from these locations without proper validation, an attacker may place a malicious file with the same name in the search path. The application may then execute the malicious file instead of the legitimate one, leading to unauthorized code execution...

**Business impact:** This vulnerability can allow attackers to execute malicious code within the affected system, potentially gaining unauthorized access or elevated privileges. Exploitation may lead to system compromise, data manipulation, service disruption, or installation of malware. Such incidents can impact business operations, lead to data breaches, and cause financial and reputational damage to the organization.

The screenshot shows the CWE-426: Untrusted Search Path page. At the top, the CWE logo and name are displayed, along with a badge indicating it is a 'Top 25' and 'Top HW CWE'. The page header includes navigation links: Home, About, Learn, Access Content, Community, and Search. The main content area is titled 'CWE-426: Untrusted Search Path' and includes the following information:

- Weakness ID:** 426
- Vulnerability Mapping:** ALLOWED (with careful review of mapping notes)
- Abstraction:** Base

Below this, there are tabs for 'View customized information': Conceptual, Operational, Mapping Friendly, Complete (selected), and Custom. The 'Description' section states: 'The product searches for critical resources using an externally-supplied search path that can point to resources that are not under the product's direct control.' The 'Extended Description' section explains that this might allow attackers to execute their own programs, access unauthorized data files, or modify configuration in unexpected ways. It also lists some common variants of untrusted search path:

- In various UNIX and Linux-based systems, the PATH environment variable may be consulted to locate executable programs, and LD\_PRELOAD may be used to locate a separate library.
- In various Microsoft-based systems, the PATH environment variable is consulted to locate a DLL, if the DLL is not found in other paths that appear earlier in the search order.

The 'Alternate Terms' section lists 'Untrusted Path'. The 'Common Consequences' section has tabs for 'Impact' and 'Details'.

## 9. Vulnerability name : Insufficient Logging

CWE/CVE number : 778

OWASP category: A09:2025 Security Logging & Alerting Failures

**Description:** Insufficient Logging occurs when an application **fails to properly record important security-related events such as login attempts, system changes, access to sensitive data, or error conditions**. Without adequate logging mechanisms, it becomes difficult to detect suspicious activities, investigate security incidents, or trace the actions performed within the system....

**Business impact:** Insufficient logging can significantly limit the organization's ability to detect, monitor, and respond to security incidents in a timely manner. If malicious activities occur, the lack of proper logs may prevent security teams from identifying the source, scope, or impact of the attack. This can result in prolonged security breaches, data loss, operational disruption, compliance violations, and reputational damage to the organization

The screenshot shows the CWE-778: Insufficient Logging page. At the top, the CWE logo and title 'Common Weakness Enumeration' are visible, along with a tagline 'A community-developed list of SW & HW weaknesses that can become vulnerabilities'. Navigation links include Home, About, Learn, Access Content, Community, and Search. A search bar is present on the right. The main heading is 'CWE-778: Insufficient Logging'. Below this, the 'Weakness ID: 778' and 'Vulnerability Mapping: ALLOWED' are displayed. A section for 'View customized information' offers filters: Conceptual, Operational, Mapping Friendly, Complete, and Custom. The 'Description' section states: 'When a security-critical event occurs, the product either does not record the event or omits important details about the event when logging it.' The 'Extended Description' section explains: 'When security-critical events are not logged properly, such as a failed login attempt, this can make malicious behavior more difficult to detect and may hinder forensic analysis after an attack succeeds. As organizations adopt cloud storage resources, these technologies often require configuration changes to enable detailed logging information, since detailed logging can incur additional costs. This could lead to telemetry gaps in critical audit logs. For example, in Azure, the default value for logging is disabled.' The 'Common Consequences' section includes a table with 'Impact' and 'Details'. The 'Impact' is 'Non-Repudiation' and the 'Details' state: 'If security critical information is not recorded, there will be no trail for forensic analysis and discovering the cause of problems or the source of attacks may become more difficult or impossible.' The 'Potential Mitigations' section is partially visible, showing a table with 'Phase(s)' and 'Mitigation'.

**CWE-778: Insufficient Logging**

Weakness ID: 778  
Vulnerability Mapping: ALLOWED  
Abstraction: Base

View customized information:

**Description**  
When a security-critical event occurs, the product either does not record the event or omits important details about the event when logging it.

**Extended Description**  
When security-critical events are not logged properly, such as a failed login attempt, this can make malicious behavior more difficult to detect and may hinder forensic analysis after an attack succeeds.  
As organizations adopt cloud storage resources, these technologies often require configuration changes to enable detailed logging information, since detailed logging can incur additional costs. This could lead to telemetry gaps in critical audit logs. For example, in Azure, the default value for logging is disabled.

**Common Consequences**

| Impact          | Details                                                                                                                                                                                                |
|-----------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Non-Repudiation | Scope: Non-Repudiation                                                                                                                                                                                 |
| Hide Activities | If security critical information is not recorded, there will be no trail for forensic analysis and discovering the cause of problems or the source of attacks may become more difficult or impossible. |

**Potential Mitigations**

| Phase(s)         | Mitigation |
|------------------|------------|
| Architecture and |            |



## 10. Vulnerability name : Uncaught Exception

CWE/CVE number : 248

OWASP category: A10:2025 Mishandling of Exceptional Conditions

**Description:** An **Uncaught Exception** occurs when an application **fails to properly handle runtime errors or exceptions**, allowing them to propagate unexpectedly. This can cause the application to crash, display sensitive system information in error messages, or behave unpredictably. Unhandled exceptions can be exploited by attackers to gather information about the system or to disrupt application functionality.....

**Business impact:** Uncaught exceptions can lead to **application crashes, service disruptions, or exposure of sensitive internal information** through error messages. Attackers may leverage this vulnerability to compromise system stability, gain insights into the application's structure, or execute further attacks. This can result in **downtime, financial losses, regulatory compliance issues, and damage to the organization's reputation and customer trust.**

The screenshot shows the CWE-248: Uncaught Exception page. The header includes the CWE logo, the text 'Common Weakness Enumeration', and a tagline 'A community-developed list of SW & HW weaknesses that can become vulnerabilities'. There are also badges for 'Top 25' and 'Top HW CWE', and a 'New to CWE? Start here!' link. The breadcrumb trail is 'Home > CWE List > CWE-248: Uncaught Exception (4.19.1)'. The page title is 'CWE-248: Uncaught Exception'. Below the title, it shows 'Weakness ID: 248', 'Vulnerability Mapping: ALLOWED', and 'Abstraction: Base'. There are buttons for 'View customized information: Conceptual, Operational, Mapping Friendly, Complete, Custom'. The 'Description' section states 'An exception is thrown from a function, but it is not caught.' The 'Extended Description' section states 'When an exception is not caught, it may cause the program to crash or expose sensitive information.' The 'Common Consequences' section has an 'Impact' section with 'DoS: Crash, Exit, or Restart; Read Application Data' and a 'Details' section with 'Scope: Availability, Confidentiality' and 'An uncaught exception could cause the system to be placed in a state that could lead to a crash, exposure of sensitive information or other unintended behaviors.' The 'Relationships' section has a 'Relevant to the view "Research Concepts" (View-1000)' section with a table:

| Nature   | Type   | ID  | Name                                        |
|----------|--------|-----|---------------------------------------------|
| ChildOf  | Green  | 705 | Incorrect Control Flow Scoping              |
| ChildOf  | Green  | 755 | Improper Handling of Exceptional Conditions |
| ParentOf | Purple | 600 | Uncaught Exception in Servlet               |

## STAGE 2 :

Title:-Nessus scan

**Overview :-** Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities. These probes can include network traffic, operating system commands, and application requests. Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities. There are over 1200 plugins available for Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices. When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides a detailed report that includes the severity of the vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to run scans on a schedule or manually.

Here is a step-by-step explanation of how Nessus works:

1. Nessus connects to the target host using a variety of protocols, including TCP, UDP, and ICMP.
2. Nessus sends a series of probes to the target host in order to identify its operating system and services.
3. Nessus runs a series of plugins to test for vulnerabilities.
4. Nessus generates a report that includes the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that can be used to prioritise remediation efforts.

Here are some of the benefits of using Nessus:

- Comprehensive vulnerability coverage: Nessus has over 1200 plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices.
- Easy to use: Nessus has a user-friendly interface that makes it easy to configure and run scans.

- Comprehensive reporting: Nessus provides detailed reports that include the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

- Scalability: Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications.

- Flexibility: Nessus can be configured to run scans on a schedule or manually.

Nessus is a powerful tool that can be used to improve the security of any network. It is a valuable asset for any security professional.

**Target website :-** <http://testfire.net/>

**Target ip address:-** 65.61.137.117

**List of vulnerability :-**

| s.no | Vulnerability Name | Severity | pulgins |
|------|--------------------|----------|---------|
| 1    | General            | Info     | 46180   |
| 2    | Port scanners      | Info     | 11219   |
| 3    | Web Servers        | Info     | 39446   |
| 4    | Service detection  | Info     | 22964   |
| 5    | Settings           | Info     | 19506   |
| 6    | General            | Info     | 209654  |
| 7    | General            | Info     | 11936   |
| 8    | General            | Info     | 277650  |
| 9    | General            | Info     | 298387  |
| 10   | General            | info     | 25220   |

## **REPORT:-**

### **1. Vulnerability Name :- General**

**Severity :-** info

**Plugin :-** 46180

**Description:-** Hostnames different from the current hostname have been collected by miscellaneous plugins. Nessus has generated a list of hostnames that point to the remote host. Note that these are only the alternate hostnames for vhosts discovered on a web server.

Different web servers may be hosted on name-based virtual hosts.

**Solution :-** If you want to test them, re-scan using the special vhost syntax, such as : [www.example.com\[192.0.32.10\]](http://www.example.com[192.0.32.10])

**Business Impact :-** This finding indicates that multiple **hostnames (virtual hosts)** are associated with the same server. While this is not a direct vulnerability, it reveals additional **domain names or virtual hosts** that point to the same IP address.

From a business perspective, undiscovered or unmanaged virtual hosts may expose **additional web applications, staging environments, or legacy services** that might not be regularly monitored or secured. Attackers could potentially use this information during the **reconnaissance phase** to identify hidden or less protected services hosted on the same server.

If any of these virtual hosts contain **misconfigured applications, outdated software, or sensitive information**, it could lead to unauthorized access, data exposure, or service disruption, which may impact **business operations, customer trust, and organizational reputation**.

Therefore, organizations should review the identified hostnames and ensure that **all associated web services are properly secured, monitored, and included in regular security assessments**.

## 2. Vulnerability Name :- Port scanners

**Severity** :- info

**Plugin** :- 11219

**Description**:- This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

**Solution** :-Protect your target with an IP filter.

**Port** :- 80

**Business Impact** :- This finding indicates that a **SYN (half-open) port scan** was performed on the target system to identify open or accessible network ports. The result itself does not represent a direct vulnerability; rather, it shows that the scanning tool was able to **probe the network services running on the host**.

From a business perspective, exposed or discoverable network ports can provide attackers with **valuable information about active services and potential entry points** into the system. If unnecessary or poorly secured services are running on open ports, they may increase the **attack surface** and could be exploited by malicious actors to gain unauthorized access, disrupt services, or compromise sensitive business data.

Additionally, repeated or uncontrolled scanning activity may affect **network performance or firewall stability**, especially in environments with less robust security infrastructure. Properly controlling access to network ports and implementing filtering mechanisms helps reduce the risk of **unauthorized reconnaissance and potential attacks on critical business systems**

### 3. **Vulnerability Name :-** Web Servers

**Severity :-** info

**Plugin :-** 39446

**Port :-** 80

**Description:-** Nessus was able to detect a remote Apache Tomcat web server.

NOTE: When paranoia levels are elevated, this plugin will also consider versions obtained from responses with non-200 HTTP status codes..

**Solution :-** n/a

**Business Impact :-** The detection of a web server such as **Apache Tomcat** indicates that the system is hosting web-based services or applications accessible over the network. Although this finding is informational, exposing web server details may provide attackers with useful information during the **reconnaissance phase** of an attack.

If the identified web server is **outdated, misconfigured, or not properly secured**, it could potentially be exploited to gain unauthorized access, compromise hosted applications, or expose sensitive business data. Additionally, publicly accessible web services increase the organization's **attack surface**, which may lead to service disruptions, data breaches, or reputational damage if not properly managed.

#### 4. **Vulnerability Name** :- Service detection

**Severity** :- info

**Plugin** :- 22964

**Description**:- Nessus was able to identify the remote service by its banner or by looking at the error message it sends when it receives an HTTP request.

**Solution** :- n/a

**Business Impact** :- Although this finding is informational, exposed **service banners or detailed error messages** may disclose sensitive information about the underlying software, service versions, or system configuration. Attackers can use this information during the **reconnaissance phase** to identify potential vulnerabilities associated with the detected services.

If outdated or vulnerable services are identified through banner information, attackers may attempt to exploit known vulnerabilities, potentially leading to **unauthorized access, service disruption, or data compromise**. This could negatively impact business operations, system availability, and organizational reputation.

## 5. Vulnerability Name :- Settings

**Severity** :- info

**Plugin** :- 19506

**Description**:- This plugin displays, for each tested host, information about the scan itself :

- The version of the plugin set.
- The type of scanner (Nessus or Nessus Home).
- The version of the Nessus Engine.
- The port scanner(s) used.
- The port range scanned.
- The ping round trip time
- Whether credentialed or third-party patch management checks are possible.
- Whether the display of superseded patches is enabled
- The date of the scan.
- The duration of the scan.
- The number of hosts scanned in parallel.
- The number of checks done in parallel.

**Solution** :- n/a

**Business Impact** :- This is an **informational finding** and does not indicate a direct security vulnerability. However, the scan configuration details provide **metadata about how the security assessment was performed**. If such information were exposed to unauthorized parties, it could potentially reveal **security testing methods, scanning coverage, or monitoring capabilities** used by the organization.

From a business perspective, understanding the scan settings helps ensure that **security assessments are properly configured, comprehensive, and aligned with organizational security policies**. Properly configured scans support effective identification of vulnerabilities and help maintain the **security posture of critical systems and business applications**.



## 6. Vulnerability Name :- General

**Severity** :- info

**Plugin** :- 209654

**Description**:- Using a combination of remote probes (TCP/IP, SMB, HTTP, NTP, SNMP, etc), it was possible to gather one or more fingerprints from the remote system. While the highest-confidence result was reported in plugin 11936, "OS Identification", the complete set of fingerprints detected are reported here..

**Solution** :- n/a

**Business Impact** :- This finding is **informational** and does not represent a direct vulnerability. However, system fingerprinting can reveal details about the **operating system, network services, and system configuration**. If similar information is accessible to unauthorized users or attackers, it may help them perform **reconnaissance and targeted attacks** by identifying the technologies used within the organization's infrastructure.

From a business perspective, excessive exposure of system information can increase the **attack surface** and may assist attackers in identifying potential vulnerabilities in operating systems or network services. This could eventually lead to **unauthorized access, service disruption, or compromise of sensitive organizational data** if exploited alongside other weaknesses.

## 7. Vulnerability Name :- General

**Severity** :- info

**Plugin** :- 11936

**Description**:- Using a combination of remote probes (e.g., TCP/IP, SMB, HTTP, NTP, SNMP, etc.), it is possible to guess the name of the remote operating system in use. It is also possible sometimes to guess the version of the operating system.

**Solution** :- n/a

**Business Impact** :- This finding is **informational** and does not represent a direct vulnerability. However, identifying the operating system and its version may provide useful information to attackers during the **reconnaissance phase** of an attack. Knowledge of the operating system allows attackers to search for **known vulnerabilities, exploits, or misconfigurations** specific to that platform.

From a business perspective, exposing operating system details may increase the **risk of targeted attacks**, which could potentially lead to **unauthorized access, system compromise, data breaches, or disruption of business services** if vulnerabilities in the identified OS are exploited.

## 8. Vulnerability Name :- General

**Severity** :- info

**Plugin** :- 277650

**Port** :- 443

**Description**:- This plugin reports network services that do not offer post-quantum ciphers. Tenable makes no attempt to determine whether the remote service would be vulnerable to a post-quantum attack.

However, cryptography that depends on the classic difficulty of solving the discrete logarithm problem or on the classic difficulty of large prime factorization is broken by Shor's algorithm. Examples of this are RSA asymmetric encryption and Diffie-Hellman key exchange.

**Solution :-** n/a

**Business Impact :-** This is an **informational finding**, but it has **future-facing security implications**:

- Services that rely solely on traditional encryption methods could become **vulnerable to quantum computing attacks** once sufficiently powerful quantum computers are available.
- From a business perspective, the absence of post-quantum ciphers may affect the **long-term confidentiality and integrity of sensitive data**, particularly for industries that require **strong data protection compliance** (finance, healthcare, government).
- Attackers could exploit cryptographic weaknesses in the future to **decrypt communications or impersonate services**, potentially compromising **business-critical information, customer data, and trust**.

While this is **not an immediate risk**, organizations should **plan for post-quantum cryptography adoption** in their security roadmap to maintain resilience against emerging threats.

## **9. Vulnerability Name :-** General

**Severity :-** info

**Plugin :-** 298387

**Port :-** 443

**Description:-** This plugin reports network services that may be vulnerable now to a future attack by adversaries using a

cryptographically relevant quantum computer (CRQC). Shor's is a theoretical algorithm that leverages the unique ability of quantum computation to do massively parallel calculations developed by Peter Shor in 1994.

This algorithm easily computes two classically difficult mathematical problems used in modern cryptography; discrete logarithms, and factoring numbers formed by multiplying large primes. Shor's reduces both of these problems from taking exponential time in chosen cases to being solvable in polynomial time.

Asymmetric encryption algorithms such as RSA, Diffie-Hellman and Elliptic Curve Diffie-Hellman are impacted by Shor's Algorithm. The most common uses of these algorithms are in symmetric key establishment and authentication. These uses render Shor's Algorithm particularly dangerous because it may give an adversary the ability to harvest network communications now, and in the future, when a CRQC becomes available, extract the symmetric key and decrypt the communication.

**Solution :- Replace affected ciphers with algorithms chosen to resist CRQC attack.**

**Business Impact :-** Although this is not an immediate threat, it represents a **strategic risk to long-term data security**:

- Communications encrypted using traditional asymmetric algorithms could eventually be **decrypted by quantum-capable adversaries**, exposing **sensitive business, customer, or intellectual property data**.
- The ability to harvest encrypted traffic now for decryption later increases the **potential attack surface and data exposure window**.
- Organizations in industries like **finance, healthcare, government, or critical infrastructure** may face regulatory or reputational risks if quantum-vulnerable communications are intercepted and later decrypted.

In short, failing to address quantum-resistant encryption may compromise **business continuity, data confidentiality, and trust** in the long term.

## 10. Vulnerability Name :- General

**Severity** :- info

**Plugin** :- 25220

**Description**:- The remote host implements TCP timestamps, as defined by RFC1323. A side effect of this feature is that the uptime of the remote host can sometimes be computed.

**Solution** :- n/a

**Business Impact** :- Although this finding is informational, exposing TCP timestamps can have some indirect security implications:

- Attackers can **estimate system uptime**, which may help them plan attacks, such as predicting when the system is most likely to reboot or identifying systems that haven't been patched recently.
- Knowledge of uptime can be used in **targeted reconnaissance** to correlate activity with system maintenance schedules, which could assist in timing attacks.
- While low-risk, combined with other information, it may contribute to **profiling the target environment** and increasing the overall attack surface.

For business-critical systems, **minimizing information disclosure** helps reduce opportunities for attackers to gather reconnaissance data.

## **STAGE 3**

**Title:-** Replace and modernize legacy VPN architectures with a cloud- native Zscaler Zero Trust solution to reduce attack surface and lateral movement

**Overview:-** Traditional VPN architectures are widely used in organizations to provide remote access to internal networks. However, legacy VPN systems often expose the entire network once a user is authenticated. This increases the attack surface and allows attackers to move laterally within the network if credentials are compromised.

To overcome these security challenges, organizations are adopting a **Zero Trust architecture**. The Zero Trust model follows the principle of “Never Trust, Always Verify.” Instead of providing full network access, users are granted access only to specific applications based on identity, device posture, and contextual security policies. A cloud-native security platform such as **Zscaler** enables secure access to applications without exposing the internal network. By implementing this approach, organizations can significantly reduce cyber threats, prevent lateral movement, and improve overall network security.

### **Identify**

**Device posture :** Device posture refers to the security status of a device that attempts to access the network or applications. Before granting access, the system checks whether the device meets security requirements such as updated operating systems, antivirus protection, and security patches. In a Zero Trust environment, only compliant and secure devices are allowed to access applications. This helps prevent compromised or insecure devices from entering the network.

**Application list :** An application list contains all the applications that users are allowed to access within the organization. Instead of giving users full network access through VPN, Zero Trust architecture provides **application-level access**. Users can only connect to the specific applications required for their work, such as email systems, student portals, or internal management systems. This approach reduces unnecessary exposure of internal resources and strengthens security.

**Context aware access :** Context aware access means that access decisions are made based on different contextual factors such as user identity, device type, location, and time of access. For example, a user accessing an application from a trusted device within the organization may be granted access easily, while access from an unknown device or unusual location may require additional verification. This intelligent access control improves security and ensures that only legitimate users can access sensitive applications.

## **CONCLUSION :**

### **Stage 1 – What I understood from Web Application Testing**

From web application testing, I understood the importance of identifying vulnerabilities in web applications. Web application testing helps detect security weaknesses such as SQL injection, cross-site scripting (XSS), authentication issues, and misconfigurations. By performing security testing, organizations can protect their web applications from cyber attacks and unauthorized access. This stage helped me understand how security testing tools and techniques are used to identify and fix vulnerabilities in web applications.

### **Stage 2 – What I understood from the Nessus Report**

From the vulnerability scanning performed using **Nessus**, I learned how security tools can identify vulnerabilities in network systems, servers, and applications. The Nessus report provides detailed information about security issues, their severity levels, and recommended solutions to fix them. By analyzing the report, I understood the importance of vulnerability assessment and how organizations can improve their security by patching and fixing identified vulnerabilities.

### **Stage 3 – What I understood from SOC / SIEM / QRadar Dashboard**

From studying Security Operations Center (SOC), Security Information and Event Management (SIEM), and the **IBM QRadar** dashboard, I understood how organizations monitor network activities and detect security threats in real time. These tools collect and analyze logs from different devices and systems to identify suspicious activities. SOC teams use these dashboards to investigate alerts, analyze incidents, and respond quickly to cyber attacks. This stage helped me understand how modern security monitoring systems protect organizations from cyber threats and improve overall cybersecurity.

## **FUTURE SCOPE :**

### **Stage 1 – Future Scope of Web Application Testing**

The future of web application testing will focus more on automation and advanced security tools. With the integration of artificial intelligence and machine learning, testing processes will become faster and more accurate in identifying vulnerabilities. Modern security testing tools will help organizations detect threats earlier and improve the overall security of web applications.

### **Stage 2 – Future Scope of the Testing Process**

The testing process will continue to evolve with improved vulnerability assessment tools and automated scanning systems. Tools such as Nessus will become more intelligent by integrating AI-based analysis and real-time monitoring. This will allow organizations to identify vulnerabilities quickly and apply security patches efficiently, leading to stronger cybersecurity practices.

### **Stage 3 – Future Scope of SOC / SIEM**

The future of Security Operations Center (SOC) and SIEM technologies will involve greater use of automation, artificial intelligence, and advanced threat detection systems. SIEM platforms such as **IBM QRadar** will use machine learning to analyze large volumes of security data and detect threats in real time. This will help organizations respond faster to cyber attacks and strengthen their overall security infrastructure.

**Topics explored :-** owasp top 10, scanning, vulnerability, awareness , identity

**Tools explored :-** Zscaler, Nessus, owasp,hackthissite